

План на 2 недели: запуск публичного сервиса по ofercie

ПЛАН_2_НЕДЕЛИ_публичная_офeрта.md

Решение от 17.08.2026: B2B-модель не делаем. Публичная офeрта на сайте, регистрация любого желающего, стартовый баланс 500 Р. **Форма:** самозанятый (плательщик НПД). **Роль:** при публичной модели вы — **оператор** персональных данных, а не обработчик по поручению.

0. Одно условие, без которого план не работает

Публичная модель выдерживает нагрузку по рискам **только на stateless-архитектуре:** содержимое документов и таблицы соответствий не сохраняются нигде. Причина простая — утечь может только то, что хранится. Офeрта, заверения пользователей и документы риск распределяют, но не устраняют; устраняет его отсутствие данных.

Задача 2.1 (stateless) — блокирующая. Пока она не сделана, публичный запуск не проводится.

1. Юридический блок

1.1. Офeрта — центральный документ

Офeрта одновременно решает три задачи: договор оказания услуг, поручение обработки по ч. 3 ст. 6 152-ФЗ (пользователь → вы) и распределение ответственности.

Обязательные разделы:

Раздел	Содержание	Основание
Предмет	«Автоматизированное выявление и маскирование (псевдонимизация) прямых идентификаторов персональных данных». Прямая оговорка: результат не является обезличиванием по п. 9 ст. 3 и сохраняет статус ПДн	Ст. 431.2 ГК
Порядок акцепта	Регистрация + подтверждение e-mail + проставление отметок. Молчание и бездействие акцептом не признаются	Ст. 428, 438 ГК
Поручение обработки	Перечень ПДн · перечень действий · цели обработки · конфиденциальность · требования ч. 5 ст. 18 и ст. 18.1 · обязанность по запросу предоставлять подтверждающие документы · безопасность · требования ст. 19 · уведомление о случаях ч. 3.1 ст. 21	Ч. 3 ст. 6 — все 9 условий
Заверения пользователя	Является оператором либо уполномочен им · располагает правовым основанием · исполнил обязанность информирования субъектов · не передаёт спецкатегории (ст. 10), биометрию (ст. 11) и сведения, составляющие гостайну · достиг 18 лет	Ст. 431.2 ГК
Согласие на субобработчиков	Перечень: ООО «ИНТЕРФОНИКА» (ИНН 3808196695), территория — РФ	Ч. 3 ст. 6

Раздел	Содержание	Основание
Ответственность	Ограничение суммой оплаченных услуг за 12 месяцев. Оговорка: ограничение не применяется к отношениям с потребителями — ст. 16 ЗоЗПП делает такие условия ничтожными	Ст. 16 ЗоЗПП
Верификация результата	Обязанность пользователя проверить результат до передачи третьим лицам. Полнота детекции — заявленная, не абсолютная	Ст. 431.2 ГК
Цена и баланс	Стартовый баланс 500 Р, тарификация, возврат	ГК
Расторжение и удаление	Порядок удаления учётной записи и данных	Ст. 21 152-ФЗ

1.2. Три отметки при регистрации — отдельно, без предустановки

#	Формулировка	Природа	Обязательна
1	«Принимаю условия Оферты, включая поручение обработки персональных данных, и подтверждаю достоверность заверений»	Договор	Да
2	«Даю согласие на обработку моих персональных данных (адрес электронной почты, платёжные данные)»	Согласие, ст. 9	Да
3	«Ознакомлен с Политикой в отношении обработки персональных данных»	Ознакомление, не согласие	Да

Отметки не должны быть предустановлены и не должны объединяться в одну. Преднажатый чекбокс — типовое нарушение, за которое Роскомнадзор штрафует чаще всего.

Сохранять доказательства акцепта: дата, время, IP, версия оферты, идентификатор пользователя. Без этого заверения недоказуемы.

1.3. Остальные документы

Документ	Статус	Что доделать
Политика обработки ПДн	Черновик готов — ГОТОВЫЕ_ДОКУМЕНТЫ/1	Переработать под роль оператора (сейчас написана под обработчика); добавить порядок обращений субъектов напрямую
Уведомление РКН	Черновик готов — ГОТОВЫЕ_ДОКУМЕНТЫ/2	Категории субъектов — «неопределённый круг лиц, ПДн которых содержатся в загружаемых документах»
Регламент инцидентов	Готов — ГОТОВЫЕ_ДОКУМЕНТЫ/3	Проставить контакты

Документ	Статус	Что доделать
Модель угроз + акт УЗ	Готов — ГОТОВЫЕ_ДОКУМЕНТЫ/4	Пересмотреть под публичную модель: рост числа субъектов, недоверенный пользователь как нарушитель
Соглашение о поручении с Интерфоникой	Шаблон 03	Довести до 9 условий; добавить отдельный пункт об ответственности за нарушение конфиденциальности — не путать с SLA

2. Технический блок

№	Задача	Почему	Приоритет
2.1	Stateless: не сохранять документ и таблицу соответствий	Условие запуска. Снимает основную часть рисков	Блокер
2.2	Аутентификация: регистрация, подтверждение e-mail, токен на каждый запрос	Без неё заверения оферты не привязать к лицу; ст. 19 ч. 2 п. 8	Блокер
2.3	Привязка job_id к пользователю	Иначе доступ к чужим документам	Блокер
2.4	Ограничение частоты запросов и объёма	Публичный сервис без него нежизнеспособен	Высокий
2.5	Предупреждение и отказ при признаках спецкатегорий	Удерживает УЗ-4. Иначе сертифицированные СЗИ становятся обязательными	Высокий
2.6	Раздельные хранилища: учётные данные ≠ содержимое документов	Смешение превращает утечку аккаунтов в утечку документов	Высокий
2.7	Фиксация акцепта оферты (дата, время, IP, версия)	Доказательство заверений	Высокий
2.8	Удаление учётной записи и данных по запросу	Ст. 21	Средний
2.9	Хеш имени файла в usage.jsonl	Имена содержат ФИО	Средний
2.10	Отзыв JupyterHub-токена и ротация ключа шлюза	Инцидент 08	Немедленно

Уже сделано 16.08.2026: режим irreversible · spans[].text не возвращается · детерминированный TTL · запрет core dump · журнал операций · CORS закрыт · секреты вынесены в окружение.

3. Календарный план

Неделя 1

День	Юридическое	Техническое
1	Начать оферту: предмет, акцепт, поручение по 9 условиям	Аутентификация: схема регистрации (2.2)
2	Оферта: заверения, ответственность, оговорка ЗоЗПП	Аутентификация: реализация
3	Переработать Политику под роль оператора	(2.3)
4	Пересмотреть модель угроз и акт УЗ под публичную модель	Начать stateless (2.1)
5-7	Резерв. Получить ответ Интерфоники	Stateless: продолжение

Неделя 2

День	Юридическое	Техническое
8	Договор поручения с Интерфоникой — финализировать и отправить на подпись	Завершить stateless
9	Регламент инцидентов: контакты, формы	Ограничение частоты и объёма (2.4)
10	Заполнить уведомление РКН	Фиксация акцепта (2.7); отдельные хранилища (2.6)
11	Оценка вреда субъектам; порядок обращений	Контроль спецкатегорий (2.5)
12	Оценка эффективности мер — до ввода в эксплуатацию (п. 4 ч. 2 ст. 19)	Удаление аккаунта (2.8); хеш имени файла (2.9)
13	Опубликовать Политику и Оферту на сайте	Финальная проверка; прогон тестов
14	Подать уведомление в РКН → запуск	Мониторинг

Уведомление подаётся до начала обработки данных реальных людей (ч. 1 ст. 22). Публичный запуск — только после подачи.

4. Коммерческое предложение — проверка формулировок

Перед публикацией сверить с 05_ГЛОССАРИЙ_терминологии.md. Категорически нельзя:

✗ «обезличивание» · ✗ «100 %» и «все персональные данные» · ✗ «данные не передаются третьим лицам» (передаются на инференс-шлюз) · ✗ «соответствует 152-ФЗ» без указания, в какой части · ✗ любая цифра полноты без протокола измерения

Можно и стоит: «обработка на территории РФ» (после подтверждения) · «маскирование прямых идентификаторов» · «документы не сохраняются на сервере» (после stateless) · «полнота выявления не менее __% по методике в приложении».

5. Про стартовый баланс 500 Р

Бесплатный доступ **не снижает** обязанностей: безвозмездный договор — тоже договор, обязанности оператора те же. Но он повышает риск: случайный пользователь загрузит что угодно.

Поэтому даже на бесплатном тарифе — регистрация, принятие оферты и заверения обязательны. Без исключений.

Отдельно про НПД: по каждому поступлению формируется чек в приложении «Мой налог». При большом числе мелких платежей это операционная нагрузка — продумать автоматизацию до запуска, а не после.

6. Что проверить у Интерфоники до подписания

Площадка и наличие апстрима · логирование промптов и использование для обучения · **область действия аттестата** — покрывает ли ваш контур · матрица разграничения ответственности по приказу ФСТЭК № 21 · **ответственность за нарушение конфиденциальности отдельным пунктом, помимо SLA по доступности.**